



Legacy Portal Backend

Final Technical Documentation

Version	1.0
Prepared for	IG-Techonology
Prepared by	saad farooq
System	Legacy Portal API (Go + Gin)

1. Executive Summary

This document describes the delivered backend platform, key enhancements implemented during the project cycle, operational behavior, and support guidance for future teams.

The backend now provides:

- Unified clinic-scoped API platform for gateways, devices, users, analytics, reports, and subscriptions.
- Production-oriented scheduling for automated report delivery with timezone support.
- Subscription-aware access control for protected data routes.
- Strengthened RBAC for staff and billing operations.
- Hardened error responses and baseline Firestore security improvements.
- Performance improvements for high-traffic dashboard workflows.

Primary runtime entrypoint:

- `cmd/api/main.go`

Primary route wiring:

- `internal/server/router.go`

2. System Architecture Overview

Core components:

- **API framework:** Gin (Go)
- **Authentication:** Firebase Auth ID token verification
- **Primary data store:** Firestore
- **Optional telemetry/gateway source:** Firebase Realtime Database (RTDB)
- **Email provider:** Mailgun
- **Billing provider:** Stripe

Execution modes:

- Trial mode (`TRIAL_MODE=true`): RTDB + trial auth middleware.
- Portal mode + RTDB (`TRIAL_MODE=false` with RTDB URL): RTDB for telemetry paths, Firestore for profile/clinic metadata.

- Portal mode + Firestore (`TRIAL_MODE=false` without RTDB URL): Firestore-first mode for core APIs.

3. Delivered Functional Scope

3.1 Device Comparison API (New)

Endpoint:

- `GET /api/devices/compare?left=<deviceId>&right=<deviceId>&days=<n>`

Delivered behavior:

- Server-side side-by-side device comparison payload (single API call).
- Input validation:
 - missing left/right → `400`
 - same device IDs → `400`
 - `days` outside `1..90` → `400`
- UTC-normalized date bucketing.
- Parallelized backend fetch for device metadata, latest readings, packets, and telemetry aggregates.
- Frontend-ready response structure (window, summary rows, packets-by-day, telemetry-by-day).

Implementation:

- `internal/devices/compare.go`
- `internal/devices/compare_test.go`
- `internal/server/docs/openapi.yaml`

3.2 Analytics Performance Optimization

Delivered behavior:

- Added in-memory dashboard cache (`45s` TTL) to reduce repeated expensive reads.
- Repository-level optimization for `ListDevicesByLastSeen` with indexed query path first.
- Safe fallback behavior when index path is not available.

Implementation:

- `internal/analytics/service.go`
- `internal/analytics/repository.go`

3.3 Email Automation Scheduler (Productionized)

Delivered behavior:

- Persistent schedule model with operational fields (`nextRunAt` , `lastRunAt` , `lastStatus` , `runCount` , etc.).
- In-process scheduler runner (`StartScheduler`) with 1-minute tick.
- Due schedule execution with lock/idempotency controls.
- Timezone-aware schedule calculations (`time/tzdata` embedded in binary).
- Stale and misaligned slot handling to prevent immediate duplicate sends.
- Manual scheduler pass endpoint for controlled operations.
- Unit tests for scheduling logic.

Endpoints:

- `GET /api/reports/email-automation/schedules`
- `POST /api/reports/email-automation/schedules`
- `PATCH /api/reports/email-automation/schedules/:id`
- `DELETE /api/reports/email-automation/schedules/:id`
- `POST /api/reports/email-automation/run-due`

Implementation:

- `internal/reports/service.go`
- `internal/reports/handler.go`
- `internal/reports/scheduler_test.go`
- `cmd/api/main.go`

3.4 Role-Based Access Hardening

Delivered behavior:

- Clinic user-management endpoints restricted to `admin` and `super_admin` .
- Subscription and billing management endpoints restricted to `admin` and `super_admin` .
- Manual scheduler run endpoint allows `admin` or `super_admin` .

Implementation:

- `internal/server/admin_middleware.go`
- `internal/server/router.go`

- `internal/subscription/handler.go`
- `internal/reports/handler.go`

3.5 Subscription Gating on Protected API Routes

Delivered behavior:

- Global subscription guard attached to `/api` route group.
- Explicit skip list only for:
 - `/api/auth/*`
 - `/api/subscription/*`
 - `/api/webhooks/*`
- Fail-closed enforcement:
 - missing principal → `401 unauthorized`
 - missing clinic context (non-super-admin) → `403 forbidden`
 - unpaid/cancelled/unknown → `402 payment_required`
- `past_due` is allowed with warning header:
 - `X-Subscription-Warning: past_due`
- Optional debug mode for decision tracing:
 - `SUBSCRIPTION_GUARD_DEBUG=true`

Implementation:

- `internal/subscription/middleware.go`
- `internal/subscription/service.go`

3.6 Error Response Hardening

Delivered behavior:

- Removed raw internal backend error exposure from client-facing `500` responses.
- Returned safe generic internal message while preserving server-side logs for diagnostics.

Implementation (representative):

- `internal/analytics/handler.go`
- `internal/devices/handler.go`
- `internal/gateways/handler.go`
- `internal/packets/handler.go`

- `internal/users/handler.go`
- `internal/auth/firebase.go`
- `internal/admin/handler.go`
- `internal/devices/compare.go`

3.7 Firestore Rules Baseline Security Update

Delivered behavior:

- Firestore rules changed from open access to authenticated-only access.

Current rule:

```
allow read, write: if request.auth != null
```

Implementation:

- `firestore.rules`

Note: This is baseline hardening. Collection-level least-privilege rules are recommended as next phase.

4. Complete Endpoint Inventory (Source of Truth)

Source used for this inventory:

- `internal/server/router.go`

Notes:

- All `/api/*` routes pass through auth middleware (except explicitly public routes below).
- Subscription guard is applied at `/api` group level, with skip list:
 - `/api/auth/*`
 - `/api/subscription/*`
 - `/api/webhooks/*`
- Some route groups are conditionally registered if dependencies are available at startup (noted below).

4.1 Public and Utility Endpoints

- GET /health - service health and runtime metadata.
- GET /docs - Swagger UI.
- GET /openapi.yaml - OpenAPI spec.
- POST /api/auth/request-password-reset - public password reset request.
- POST /api/webhooks/stripe - public Stripe webhook.

4.2 Auth Endpoints (/api/auth/*)

Registered when Auth API handler is available:

- GET /api/auth/me
- POST /api/auth/claim-clinic
- POST /api/auth/request-signin-otp
- POST /api/auth/verify-signin-otp

4.3 Gateway Endpoints

- GET /api/gateways
- GET /api/gateways/:id
- GET /api/gateways/:id/devices
- GET /api/gateways/:id/sensor_readings
- GET /api/gateways/:id/health_readings

4.4 Device and Packet Endpoints

- GET /api/devices
- GET /api/devices/compare
- GET /api/devices/:id
- GET /api/devices/:id/latest
- GET /api/devices/:id/packets
- GET /api/devices/:id/telemetry
- GET /api/devices/:id/compliance

- GET /api/devices/:id/packets_by_day

4.5 Analytics Endpoints

- GET /api/analytics/summary
- GET /api/analytics/dashboard
- GET /api/analytics/activity_over_time

4.6 User Endpoints

- GET /api/users
- GET /api/users/:id
- GET /api/users/:id/units
- GET /api/users/:id/units/:unitId/events
- GET /api/users/:id/units/:unitId/history

4.7 Admin Endpoints (/api/admin/*)

Registered when Admin handler is available. Authorization middleware: RequireSuperAdmin()

- POST /api/admin/users
- GET /api/admin/users

4.8 Clinic User-Management Endpoints (/api/clinic/users*)

Registered when Clinic handler is available. Authorization middleware: RequireAdminOrSuperAdmin()

- POST /api/clinic/users
- GET /api/clinic/users
- PUT /api/clinic/users/:uid
- PUT /api/clinic/users/:uid/reactivate
- PATCH /api/clinic/users/:uid/devices
- DELETE /api/clinic/users/:uid

4.9 Reports Endpoints (`/api/reports/*`)

Registered when Reports handler is available.

- `POST /api/reports/email/send`
- `GET /api/reports/email-automation/schedules`
- `POST /api/reports/email-automation/schedules`
- `PATCH /api/reports/email-automation/schedules/:id`
- `DELETE /api/reports/email-automation/schedules/:id`
- `POST /api/reports/email-automation/run-due`

4.10 Subscription and Billing Endpoints (`/api/subscription/*`)

Registered when Subscription handler is available. Authorization middleware:

`RequireAdminOrSuperAdmin()`

- `GET /api/subscription/status`
- `GET /api/subscription/billing-overview`
- `GET /api/subscription/payment-method`
- `GET /api/subscription/invoices`
- `POST /api/subscription/create-checkout`
- `POST /api/subscription/cancel`
- `POST /api/subscription/resume`
- `POST /api/subscription/create-portal-session`
- `POST /api/subscription/change-plan`

4.11 Detailed Endpoint Behavior

This section provides practical behavior-level documentation for each route.

Public and Utility

`GET /health`

Returns service health, current UTC timestamp, environment label, and trial-mode flag (when enabled). Used by monitoring and deployment checks.

GET /docs

Serves interactive API documentation UI.

GET /openapi.yaml

Returns OpenAPI specification served by backend runtime.

POST /api/auth/request-password-reset

Public endpoint that accepts email and triggers Firebase reset-link generation + email dispatch via Mailgun. Returns a generic success message to avoid account enumeration.

POST /api/webhooks/stripe

Public Stripe webhook receiver. Verifies Stripe signature, processes billing lifecycle events, and updates clinic subscription snapshot fields.

Auth

GET /api/auth/me

Returns authenticated principal information (**uid** , **email** , **clinicId** , **role** , **accountType**) plus clinic metadata when available.

POST /api/auth/claim-clinic

Accepts clinic code and links/moves eligible account into target clinic context.

POST /api/auth/request-signin-otp

Sends one-time sign-in verification code to authenticated user email.

POST /api/auth/verify-signin-otp

Verifies submitted OTP code and marks session as OTP-verified (token refresh required afterwards).

Gateways

GET /api/gateways

Lists gateways visible to the caller's clinic/scope.

GET /api/gateways/:id

Returns single gateway details if caller has clinic/scope access.

GET /api/gateways/:id/devices

Lists devices attached to a gateway, filtered by caller's clinic/device scope.

GET /api/gateways/:id/sensor_readings

Returns gateway environment/sensor telemetry series for charts/monitoring.

GET /api/gateways/:id/health_readings

Returns gateway health telemetry series for operations and trend analysis.

Devices and Packets

GET /api/devices

Lists devices in caller scope with clinic-aware filtering.

GET /api/devices/compare

Returns fully prepared side-by-side compare payload for two devices (headers, summary rows, packets by day, telemetry by day).

GET /api/devices/:id

Returns detailed metadata for one device, scope-protected.

GET /api/devices/:id/latest

Returns latest decoded reading snapshot for selected device.

GET /api/devices/:id/packets

Returns raw/recent packet rows for selected device with pagination/filtering support.

GET /api/devices/:id/telemetry

Returns normalized telemetry response for charting (**hours** / **days** or explicit range).

GET /api/devices/:id/compliance

Returns hour-based compliance calculation derived from treatment progression.

GET /api/devices/:id/packets_by_day

Returns daily packet count aggregation for selected date window.

Analytics

GET /api/analytics/summary

Returns clinic-level KPI counts (**gateways** , **devices** , **users** , **staff**) after scope filtering.

GET /api/analytics/dashboard

Returns summary plus devices sorted by **lastSeen** , with short-lived server cache for hot dashboard views.

GET /api/analytics/activity_over_time

Returns day-wise active-device trend for selected period.

Users

GET /api/users

Lists clinic users visible to caller scope.

GET /api/users/:id

Returns one user profile in caller's clinic scope.

GET /api/users/:id/units

Returns units associated with user.

GET /api/users/:id/units/:unitId/events

Returns event timeline for specific user unit.

GET /api/users/:id/units/:unitId/history

Returns history records for specific user unit.

Super Admin

POST /api/admin/users

Super-admin provisioning endpoint for staff account creation (nurse/doctor) with clinic assignment.

GET /api/admin/users

Super-admin endpoint to list staff records by clinic.

Clinic User Management (Admin/Super Admin)

POST /api/clinic/users

Creates clinic-level user/staff account with role/device assignment.

GET /api/clinic/users

Lists clinic-managed users for administration UI.

PUT /api/clinic/users/:uid

Deactivates target clinic user.

PUT /api/clinic/users/:uid/reactivate

Reactivates previously deactivated clinic user.

PATCH /api/clinic/users/:uid/devices

Updates assigned device list for target clinic user.

DELETE /api/clinic/users/:uid

Deletes target clinic user account record.

Reports and Scheduling

POST /api/reports/email/send

Sends on-demand report email for selected kind/scope/date range.

GET /api/reports/email-automation/schedules

Lists saved automation schedules for caller clinic.

POST /api/reports/email-automation/schedules

Creates a new automation schedule (daily/weekly/monthly).

PATCH /api/reports/email-automation/schedules/:id

Updates schedule configuration and recomputes operational timing fields.

DELETE /api/reports/email-automation/schedules/:id

Deletes schedule and writes audit trail.

POST /api/reports/email-automation/run-due

Triggers one manual scheduler pass to execute currently due schedules.

Subscription and Billing (Admin/Super Admin)

GET /api/subscription/status

Returns normalized subscription state for clinic (**status**, **plan**, **current_period_end**).

GET /api/subscription/billing-overview

Returns billing summary including status, plan, period details, and upcoming invoice when available.

GET /api/subscription/payment-method

Returns masked default card/payment method metadata.

GET /api/subscription/invoices

Returns paginated clinic invoice history.

POST /api/subscription/create-checkout

Creates Stripe checkout session for requested plan and returns redirect URL.

POST /api/subscription/cancel

Cancels subscription immediately or at period end.

POST /api/subscription/resume

Resumes cancelled/paused subscription when applicable.

POST /api/subscription/create-portal-session

Creates Stripe billing portal session and returns portal URL.

POST /api/subscription/change-plan

Changes plan (monthly/yearly) with selectable proration behavior.

5. Standard Error Contract for Client Integrations

Client applications should rely on HTTP status and `error.code`, not text matching.

Response shape:

```
{
  "success": false,
  "error": {
    "code": "string_code",
    "message": "human_message"
  }
}
```

Important integration statuses:

- `400 bad_request`
- `401 unauthorized`
- `403 forbidden`
- `402 payment_required`
- `404 not_found`
- `500 internal`

6. Deployment and Operations

Test deployment script: `deploy-backend-test.sh`

Current test runtime characteristics:

- Cloud Run service: `legacy-portal-api-test`
- Region: `europe-west2`
- Environment: `APP_ENV=testing`
- Scheduler enabled: `REPORTS_SCHEDULER_ENABLED=true`
- Subscription guard debug enabled on test: `SUBSCRIPTION_GUARD_DEBUG=true`

Operational commands:

- **Deploy test:** `./deploy-backend-test.sh`

- **Verify active Cloud Run revision:**

```
gcloud run services describe legacy-portal-api-test --region europe-west2 --  
format='value(status.latestReadyRevisionName,status.traffic)'
```

- **Read subscription guard traces (test):**

```
gcloud run services logs read legacy-portal-api-test --region europe-west2 --limit=100  
| grep sub-guard
```

7. Validation and Acceptance Checklist

Authentication and Scope

- User token verification successful.
- Principal has expected role and clinic scope.

Device Compare API

- Valid compare request returns normalized dataset.
- Invalid inputs return correct `400` responses.

Analytics Performance

- Dashboard endpoint remains stable on repeated refreshes.
- Device list ordering behaves correctly by `lastSeen`.

Scheduler

- Timezone values accepted for valid IANA zones.
- Due schedules execute once per slot (no duplicate immediate sends).
- Manual run endpoint role restrictions enforced.

Subscription Enforcement

- Unpaid/cancelled non-super-admin users receive `402 payment_required` on protected routes.
- Active users receive expected `200` responses.

Error Handling

- Internal failures do not leak raw backend error details to client.

8. Known Constraints and Recommendations

1. Subscription provisioning data quality:

- Access gating depends on `clinics/{clinicId}.subscription_status`.
- If external onboarding scripts incorrectly set `subscription_status=active`, protected routes will be allowed by design.
- Recommendation: enforce correct initial status (`unpaid` until Stripe confirmation).

2. Firestore security rules:

- Current rules are authenticated-only baseline.
- Recommendation: introduce role- and clinic-scoped allow rules for direct client access paths.

3. Operational debug flags:

- `SUBSCRIPTION_GUARD_DEBUG` should remain enabled in testing only.

4. Secrets hygiene:

- Any embedded/static credentials in deployment scripts should be migrated to secret manager based injection.

9. Ownership and Future Maintenance

Primary maintenance areas:

- API contracts and RBAC: `internal/server/*`, `internal/auth/*`
- Reporting and scheduler: `internal/reports/*`
- Subscription and billing: `internal/subscription/*`
- Performance and analytics: `internal/analytics/*`
- Firestore schema/rules: `internal/firestore/*`, `firestore.rules`

Recommended quarterly maintenance:

- Re-run API security and RBAC regression tests.
- Review scheduler logs and run metrics.
- Audit subscription-state consistency against Stripe.
- Refresh and validate OpenAPI documentation against router.

10. Document Scope Statement

This document records the backend implementation status and operational behavior as delivered in the final project cycle and is intended as the formal technical handover baseline for future client and engineering teams.